



**ESCOLA VAI NA WEB
TURMA CYBERSEC 2025**

Arihel Martins Secron

Projeto Conceitual Módulo 2 - Consultoria Blue Team para Cliente

Professor: José Menezes

**Rio de Janeiro
2025**

Proposta Técnica – Consultoria Blue Team

Autor: Arihel Martins Secron

Data: 26 de Setembro de 2025 **Versão:** 1.0

Sumário Executivo

Esta proposta apresenta um plano estratégico de cibersegurança para a LojaZeta, desenhado para proteger a plataforma de e-commerce contra ameaças digitais, garantir a continuidade do negócio e preservar a confiança dos clientes.

Riscos-Chave Identificados: A análise da arquitetura atual e do cenário de ameaças para o varejo online aponta para três riscos principais que podem impactar severamente a operação e a reputação da LojaZeta:

1. **Vazamento de Dados de Clientes:** Um ataque bem-sucedido (via SQL Injection, por exemplo) pode expor dados pessoais e de pagamento, resultando em perdas financeiras, danos à marca e sanções sob a Lei Geral de Proteção de Dados (LGPD).
2. **Indisponibilidade do Serviço:** Ataques de negação de serviço (DDoS) ou falhas de segurança podem tirar a loja do ar, causando perda direta de receita e frustração dos clientes.
3. **Fraude Financeira e Comprometimento de Contas:** A exploração de vulnerabilidades pode permitir que invasores realizem transações fraudulentas ou assumam o controle de contas de usuários, gerando prejuízos e desconfiança.

Visão da Solução: Nossa estratégia se baseia em uma abordagem de Defesa em Profundidade, que consiste na criação de múltiplas camadas de segurança. A solução abrange três pilares fundamentais:

- **Arquitetura de Defesa Resiliente:** Segmentação da rede, implementação de um Web Application Firewall (WAF) para filtrar tráfego malicioso e fortalecimento (hardening) de todos os servidores.
- **Monitoramento e Detecção Proativa:** Centralização de logs em uma plataforma SIEM para obter visibilidade completa, correlacionar eventos e gerar alertas em tempo real sobre atividades suspeitas.
- **Resposta a Incidentes Estruturada:** Adoção do framework NIST para garantir que, na ocorrência de um incidente, a resposta seja rápida, eficaz e coordenada, minimizando o impacto.

Ganhos Esperados: A implementação deste plano trará benefícios tangíveis para o negócio, incluindo a redução significativa do risco de incidentes de segurança, o aumento da resiliência operacional da plataforma e a proteção da reputação da marca LojaZeta. Adicionalmente, fortalecerá a conformidade com a LGPD e aumentará a confiança dos clientes, que são a base do sucesso no e-commerce.

Escopo e Metodologia

Escopo da Proposta: Esta consultoria abrange a análise e recomendação de controles de segurança para a infraestrutura da aplicação web da LojaZeta. Estão incluídos no escopo:

- A arquitetura de defesa em nuvem para a aplicação Node.js e o banco de dados PostgreSQL.
- A estratégia de monitoramento de segurança, coleta de logs e configuração de alertas via SIEM.
- O plano de Resposta a Incidentes, incluindo a criação de runbooks para os cenários de ameaça mais prováveis.
- Um roadmap de implementação priorizado para os próximos 6 meses.

Fora do Escopo: Esta proposta não cobre os seguintes itens, que podem ser tratados em projetos futuros:

- Segurança da rede corporativa interna da LojaZeta.
- Segurança de endpoints (notebooks de funcionários).
- Testes de invasão (Pentest), embora sua contratação seja recomendada no roadmap.
- Políticas de segurança e conscientização para todos os colaboradores.

Metodologia e Assunções: A análise foi conduzida utilizando como base o diagrama de arquitetura fornecido e frameworks de segurança reconhecidos no mercado, como o OWASP Top 10 para riscos de aplicação web e o NIST Cybersecurity Framework para gestão de incidentes.

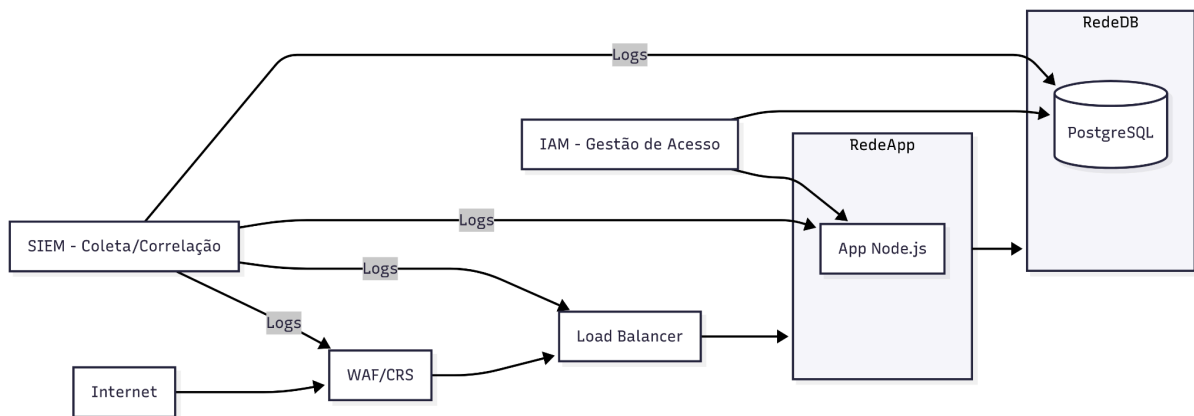
As seguintes assunções foram feitas:

- A infraestrutura da LojaZeta está hospedada em um provedor de nuvem moderno (ex: AWS, Google Cloud, Azure).
- A empresa está sujeita às regulamentações da Lei Geral de Proteção de Dados (LGPD).
- Existe uma equipe técnica interna (desenvolvimento/infraestrutura) com capacidade para implementar as recomendações propostas com o nosso apoio.
- Os componentes da arquitetura (WAF, Load Balancer, Servidores) possuem capacidade de gerar e exportar logs de auditoria.

Arquitetura de Defesa (Camadas)

A arquitetura de segurança proposta para a LojaZeta baseia-se no princípio de Defesa em Profundidade (Defense-in-Depth). Isso significa que, em vez de depender de uma única proteção, criamos múltiplas barreiras de segurança. Se um invasor conseguir contornar uma camada, ele ainda enfrentará outras, aumentando a probabilidade de detecção e bloqueio.

A arquitetura visual é a seguinte:



As camadas de defesa são compostas por:

- Segmentação de Rede: A primeira e mais crítica barreira interna.
 - DMZ (Zona Desmilitarizada): O WAF e o Load Balancer residirão nesta zona, que é a única exposta diretamente à internet.
 - Rede de Aplicação: Os servidores Node.js ficarão em uma sub-rede separada. As regras de firewall permitirão tráfego vindo apenas do Load Balancer na porta da aplicação (ex: porta 3000). Nenhum acesso direto da internet será permitido.
 - Rede de Banco de Dados: O PostgreSQL ficará em uma terceira sub-rede, ainda mais restrita. Apenas os servidores da Rede de Aplicação poderão se comunicar com o banco de dados na porta específica (ex: 5432).
- WAF (Web Application Firewall):
 - Função: Atuará como um escudo para a aplicação, inspecionando todo o tráfego HTTP/S em busca de padrões de ataque conhecidos.
 - Recomendação: Implementar um WAF com o OWASP Core Rule Set (CRS) ativado em modo de bloqueio. Ele é essencial para mitigar riscos comuns como SQL Injection (SQLi), Cross-Site Scripting (XSS) e outros ataques do OWASP Top 10.
- Hardening de Servidores (Sistema Operacional e Aplicação):
 - Princípio do Privilégio Mínimo: Todos os serviços (Nginx, Node.js, PostgreSQL) devem rodar com usuários que possuam o mínimo de permissões necessárias para sua operação.
 - Minimização da Superfície de Ataque: Desinstalar todos os softwares e desabilitar todos os serviços que não sejam estritamente necessários para o funcionamento da LojaZeta.
 - Gestão de Patches: Estabelecer um processo rigoroso para aplicar atualizações de segurança em todos os sistemas (SO, Node.js, Nginx, PostgreSQL) assim que forem disponibilizadas.
- Gestão de Identidade e Acesso (IAM):
 - Acesso Administrativo: Todo acesso SSH ou a painéis de controle deve ser protegido com Autenticação Multifator (MFA).

- Credenciais de Aplicação: As senhas e chaves de API (ex: conexão com o banco de dados) devem ser armazenadas em um cofre de segredos (como AWS Secrets Manager ou HashiCorp Vault) e não diretamente no código-fonte.
- Backup e Continuidade:
 - Banco de Dados: Configurar backups diários automatizados do PostgreSQL, com retenção de pelo menos 30 dias.
 - Aplicação: Manter cópias versionadas do código-fonte e das configurações dos servidores.
 - Teste de Restauração: Realizar testes de restauração trimestrais para garantir que os backups estão íntegros e que a equipe sabe como proceder em uma emergência.

Monitoramento & SIEM (Security Information and Event management)

A visibilidade é a base da detecção. Uma solução de SIEM centralizará e correlacionará logs de todas as camadas da nossa arquitetura para identificar atividades suspeitas que passariam despercebidas em análises isoladas.

- Fontes de Log Essenciais:
 - WAF/Load Balancer: Logs de todas as requisições (permitidas e bloqueadas), incluindo IP de origem, URL acessada e regra de WAF que foi acionada.
 - Sistema Operacional (Servidores): Logs de autenticação (sucessos e falhas de login), execução de comandos (sudo) e eventos de sistema.
 - Aplicação (Node.js): Logs de erros da aplicação, eventos de autenticação de usuários (login sucesso/falha), e transações de negócio importantes.
 - Banco de Dados (PostgreSQL): Logs de conexões, consultas lentas ou com erros (potencial indicativo de SQLi) e atividades de usuários administrativos.
- Casos de Uso para Correlação e Alertas (Exemplos):
 - Alerta de Brute-Force: SE houver mais de 10 tentativas de login falhas para o mesmo usuário em menos de 5 minutos na aplicação, ENTÃO gerar um alerta de Média Prioridade.
 - Alerta de SQL Injection: SE o WAF bloquear uma tentativa de SQLi de um IP E no mesmo minuto o Banco de Dados registrar um erro de sintaxe SQL vindo do servidor da aplicação, ENTÃO gerar um alerta de Alta Prioridade.
 - Alerta de Acesso Suspeito: SE um login administrativo (SSH ou App) ocorrer de um país fora do Brasil OU fora do horário comercial (08h-18h), ENTÃO gerar um alerta de Média Prioridade.
- KPIs (Key Performance Indicators) / Métricas:
 - MTTD (Mean Time to Detect): Tempo médio para detectar um incidente desde o momento em que ele ocorre. Nosso objetivo inicial é < 1 hora.
 - MTTR (Mean Time to Respond): Tempo médio para conter e erradicar uma ameaça após a detecção. Objetivo inicial: < 4 horas.

- Tentativas de Ataque Bloqueadas no WAF: Métrica diária para visualizar o volume de ameaças que são barradas na primeira camada.
- % de Cobertura de Logs: Percentual de ativos críticos que estão enviando logs corretamente para o SIEM. Objetivo: 100%.

Resposta a Incidentes

Um plano de resposta a incidentes (IR) garante que, quando um evento de segurança ocorrer, a equipe aja de forma rápida, coordenada e eficaz, minimizando o impacto no negócio.

O ciclo de vida da resposta será:

Preparação → Detecção & Análise → Contenção → Erradicação & Recuperação → Pós-Incidente (Lições Aprendidas)

Abaixo, estão esboços de runbooks para incidentes específicos:

Runbook 1: Tentativa de SQL Injection (SQLi)

- Detecção: Alerta de Alta Prioridade no SIEM correlacionando um bloqueio no WAF com um erro no log do PostgreSQL.
- Análise: Analista confirma que a query bloqueada é maliciosa. Verifica se algum servidor da aplicação apresenta comportamento anômalo.
- Contenção:
 - Imediata: Bloquear permanentemente o IP de origem do ataque no WAF/Firewall.
 - Curto Prazo: Se houver suspeita de comprometimento, isolar o servidor da aplicação da rede para análise forense.
- Erradicação:
 - Identificar a vulnerabilidade no código-fonte da aplicação Node.js.
 - Desenvolver e aplicar o patch de correção em ambiente de homologação.
 - Analisar o banco de dados em busca de dados alterados, exfiltrados ou contas criadas pelo invasor.
- Recuperação:
 - Restaurar o banco de dados a partir do último backup íntegro (se necessário).
 - Implantar a versão corrigida da aplicação em produção.
 - Monitorar intensivamente os logs por 24 horas.
- Lições Aprendidas: Revisar o processo de desenvolvimento seguro (SDL) para evitar futuras falhas de SQLi. Adicionar a assinatura do ataque ao WAF como uma regra customizada.

Runbook 2: Ataque de Brute-Force na Aplicação

- Detecção: Alerta do SIEM sobre múltiplas falhas de login de um mesmo IP.

- **Análise:** Verificar se o ataque está focado em um único usuário ou em vários. Checar se alguma tentativa foi bem-sucedida.
- **Contenção:** Bloquear temporariamente (ex: por 1 hora) o IP de origem no WAF.
- **Erradicação:** O ataque é mitigado pela contenção. Não há erradicação no servidor.
- **Recuperação:** O serviço já está normalizado. Se alguma conta foi comprometida, forçar a troca de senha do usuário.
- **Lições Aprendidas:** Implementar uma política de bloqueio de contas após X tentativas falhas. Recomendar o uso de senhas mais fortes e a ativação de MFA para os clientes.

Runbook 3: Indisponibilidade do Serviço (Origem Desconhecida)

- **Deteção:** Alertas de monitores externos (site fora do ar) ou alta latência na aplicação.
- **Análise:**
 - Verificar o dashboard do WAF/Load Balancer: há um pico anômalo de tráfego (possível ataque DDoS)?
 - Verificar logs da aplicação e servidores: há erros críticos, consumo excessivo de CPU ou memória?
 - Verificar o status do banco de dados: está online e respondendo?
- **Contenção:**
 - Se for DDoS: Ativar o modo "Under Attack" em serviços de WAF/CDN (como Cloudflare) para mitigar o tráfego malicioso.
 - Se for Falha Interna: Isolar o componente defeituoso (ex: reiniciar um servidor de aplicação que travou).
- **Erradicação:**
 - DDoS: Manter as proteções ativas até o ataque cessar.
 - Falha Interna: Identificar a causa raiz (ex: bug no código, query pesada no DB) e aplicar uma correção.
- **Recuperação:** Restaurar o serviço à sua plena capacidade. Validar que o site está funcional.
- **Lições Aprendidas:** Melhorar as regras de rate limiting no WAF. Otimizar a query que causou o problema. Aumentar a capacidade dos servidores se o problema foi de sobrecarga legítima.

Recomendações (80/20) e Roadmap (30/90/180 dias)

Aplicando o princípio de Pareto (80/20), focamos em ações de alto impacto e esforço gerenciável para gerar resultados de segurança rapidamente.

Fase 1: Quick Wins (Primeiros 30 dias) – Fundação da Segurança

Objetivo: Fechar as portas mais óbvias e de maior risco.

Ação	Descrição	Responsável Sugerido
1. Implantar WAF Gerenciado	Ativar um WAF (ex: Cloudflare ou AWS WAF) com o conjunto de regras base da OWASP para bloquear ataques comuns.	Equipe de Infraestrutura
2. Forçar MFA para Admins	Habilitar a Autenticação Multifator em todas as contas com acesso privilegiado (provedor de nuvem, SSH, DB).	Equipe de Infraestrutura
3. Centralizar Logs Essenciais	Configurar todos os componentes para enviarem seus logs a um local centralizado (ex: AWS CloudWatch, Google Cloud Logging).	Equipe de Infraestrutura/Devs
4. Revisar e Aplicar Patches Críticos	Realizar uma varredura inicial e aplicar todas as atualizações de segurança críticas nos servidores e software.	Equipe de Infraestrutura

Fase 2: Médio Prazo (31 a 90 dias) – Visibilidade e Estrutura

Objetivo: Construir a capacidade de detectar e responder a ameaças de forma estruturada.

Ação	Descrição	Responsável Sugerido
1. Implementar SIEM (Prova de Conceito)	Iniciar a implantação de uma solução SIEM (ex: Wazuh) e configurar os alertas básicos definidos na seção 4.	Equipe de Infraestrutura
2. Implementar Segmentação de Rede	Criar as sub-redes de segurança (DMZ, App, DB) e aplicar as regras de firewall para isolar os componentes.	Equipe de Infraestrutura
3. Testar Runbooks de Resposta	Realizar um exercício simulado (<i>tabletop exercise</i>) para testar os <i>runbooks</i> de SQLi e Brute-Force.	Gestor de TI / Equipes
4. Testar Rotina de Backup/Restore	Executar o primeiro teste completo de restauração do banco de dados para validar a integridade dos backups.	Equipe de Infraestrutura

Fase 3: Longo Prazo (91 a 180 dias) – Maturidade e Proatividade

Objetivo: Amadurecer os processos e validar as defesas de forma proativa.

Ação	Descrição	Responsável Sugerido
1. Contratar Teste de Invasão (Pentest)	Contratar uma empresa externa para realizar um teste de invasão completo na aplicação e infraestrutura.	Gestor de TI
2. Implantar Cofre de Segredos	Migrar as credenciais de acesso (senhas de banco de dados, chaves de API) do código para um cofre seguro.	Equipe de Desenvolvimento
3. Refinar Alertas do SIEM	Com base nos dados coletados, criar regras de correlação mais avançadas e reduzir falsos positivos.	Equipe de Infraestrutura
4. Treinamento de DevSecOps	Prover treinamento para a equipe de desenvolvimento sobre práticas de codificação segura (Secure Coding).	Gestor de TI / Devs

Riscos, Custos e Assunções

Riscos e Limitações do Projeto:

- Dependência da Equipe Interna: O sucesso do roadmap depende da disponibilidade e do engajamento da equipe técnica da LojaZeta.
- Complexidade de Implementação: A segmentação de rede ou a implantação de um SIEM podem introduzir complexidade e exigir ajustes na operação atual.
- Impacto no Desempenho: Controles de segurança mal configurados podem, em casos raros, impactar a performance da aplicação. Acompanhamento e testes são essenciais.

Orçamento Estimado para Ferramentas (Anual):

Os custos podem variar drasticamente entre soluções de código aberto (custo em horas/servidor) e comerciais (licenciamento/SaaS).

Ferramenta	Opção Open Source (Custo Indireto)	Opção Comercial (Estimativa)
WAF	ModSecurity (requer gestão intensiva)	Cloudflare Pro/Business: R\$ 1.200 - R\$ 2.400
SIEM	Wazuh / OpenSearch (custo de servidores e pessoal)	SaaS (Splunk, Datadog): R\$ 15.000 - R\$ 50.000+
Cofre de Segredos	HashiCorp Vault (custo de servidores)	AWS Secrets Manager (pay-per-use): R\$ 500 - R\$ 2.000
Teste de Invasão	N/A	Serviço de Consultoria: R\$ 10.000 - R\$ 30.000

Assunções Chave:

- Assume-se que haverá orçamento aprovado para as ferramentas e serviços recomendados no roadmap.
- Assume-se que a equipe da LojaZeta terá autonomia para realizar as mudanças necessárias na arquitetura e no código.
- Assume-se que as janelas de manutenção necessárias para aplicar mudanças críticas (como a segmentação de rede) serão disponibilizadas pela área de negócio.

Conclusão

A segurança não é um projeto com início, meio e fim, mas um processo contínuo de melhoria. A implementação das recomendações contidas nesta proposta elevará o nível de maturidade em cibersegurança da LojaZeta de um estado reativo para um estado proativo e resiliente, tornando-a um alvo muito mais difícil e menos atrativo para cibercriminosos.

Próximos Passos:

1. Reunião de Alinhamento: Apresentar esta proposta para todas as partes interessadas (diretoria, equipes técnica e de negócio) para esclarecer dúvidas.
2. Aprovação do Roadmap e Orçamento: Aprovar a execução da Fase 1 (30 dias) e o orçamento para as ferramentas necessárias.
3. Kick-off Técnico: Realizar uma reunião de início com as equipes responsáveis para detalhar o plano de ação da primeira fase.

Critérios de Sucesso: O sucesso deste projeto será medido pelo alcance das seguintes metas em um prazo de 6 a 12 meses:

- Atingir as metas de MTTD (< 1 hora) e MTTR (< 4 horas) para incidentes críticos.
- Passar por um teste de invasão externo sem a identificação de nenhuma vulnerabilidade crítica.
- Reduzir em mais de 90% os incidentes relacionados a ataques de força bruta e tentativas de SQL Injection.
- Garantir que 100% dos ativos críticos da infraestrutura tenham seus logs monitorados pelo SIEM.